



数据安全技术



1.数据要素背景



2.数据安全技术



Part

1

数据要素背景



数据已成为继土地、劳动力、资本、技术之后的**第五大生产要素**



中华人民共和国中央人民政府

www.gov.cn



首页 | 简 | 繁 | EN | 登录 | 注册

首页 > 政策 > 国务院政策文件库 > 国务院部门文件

字号: 默认 大 超大

打印



收藏 ☆ 留言



标题: 国家数据局关于印发《可信数据空间发展行动计划(2024—2028年)》的通知 发文机关: 国家数据局

发文字号: 国数资源〔2024〕119号

来源: 国家数据局网站

主题分类: 工业、交通、信息产业(含电信)

公文种类: 通知

成文日期: 2024年11月21日

国家数据局关于印发《可信数据空间发展行动计划(2024—2028年)》的通知

国数资源〔2024〕119号

各省、自治区、直辖市及计划单列市、新疆生产建设兵团数据管理部门,有关中央企业、行业协会:

为贯彻落实党的二十届三中全会决策部署,引导和支持可信数据空间发展,促进数据要素合规高效流通使用,支撑构建全国一体化数据市场,国家数据局组织编制了《可信数据空间发展行动计划(2024—2028年)》。现印发给你们,请结合实际,抓好落实。

国家数据局

2024年11月21日

附件:可信数据空间发展行动计划(2024—2028年).pdf

数据要素具有强大的赋能作用

数字经济

数字政府

数字社会

基础

赋能

赋能

数据要素

- 2023年,我国数字经济规模达到**53.9万亿元**,占GDP比重达到**42.8%**
- 我国一、二、三产业数字经济渗透率分别为**10.78%、25.03%和45.63%**。



数据和隐私泄露问题日益严重

2024年



PowerSchool



Personalized Education for Every Journey

PowerSchool超千万
中小學生個人數據泄露



BAYVIEW



As of September 30, 2024, Bayview managed approximately

\$19.7 billion

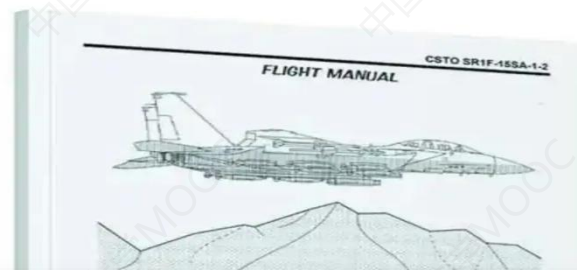
Bayview金融公司泄露
近600万客户敏感数据



大众汽车数据泄漏，
80万车主可被定位



云数据巨头Snowflake
约6.4亿条客户数据泄露



大批美军战斗机的机密性
手册被放到网上任人下载

STRAVA

运动软件Strava追踪记录，
马克龙出访路线因此暴露

政治、经济、民生.....无一幸免



数据要素合规背景

拟解决的问题

数据滥用

个人隐私

数据泄露

信息犯罪



数据安全法律



《网络数据安全条例》2025. 1. 1实施



面临的挑战

海量数据 处理难

数据模态 类型多

个保合规 需求广

安全合规 成本高

数据法律 种类繁

2021 年度与数据安全和个人信息保护相关立法活动就达75次

2022年7月，对滴滴全球股份有限公司处人民币80.26亿元罚款

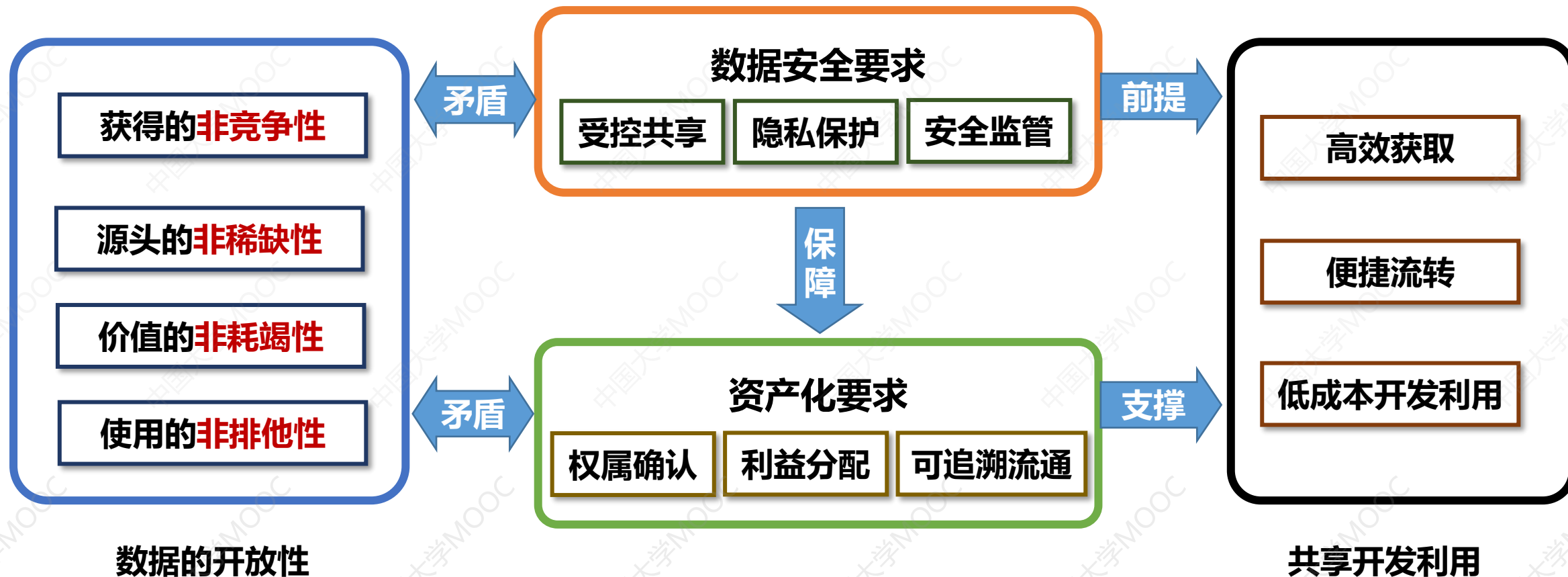


在保障数据安全的前提下实现数据**高效受控共享**和**有序开发利用**

数据的本质属性

数据的内在要求

数据的应用需求





Part **2**

数据安全技术





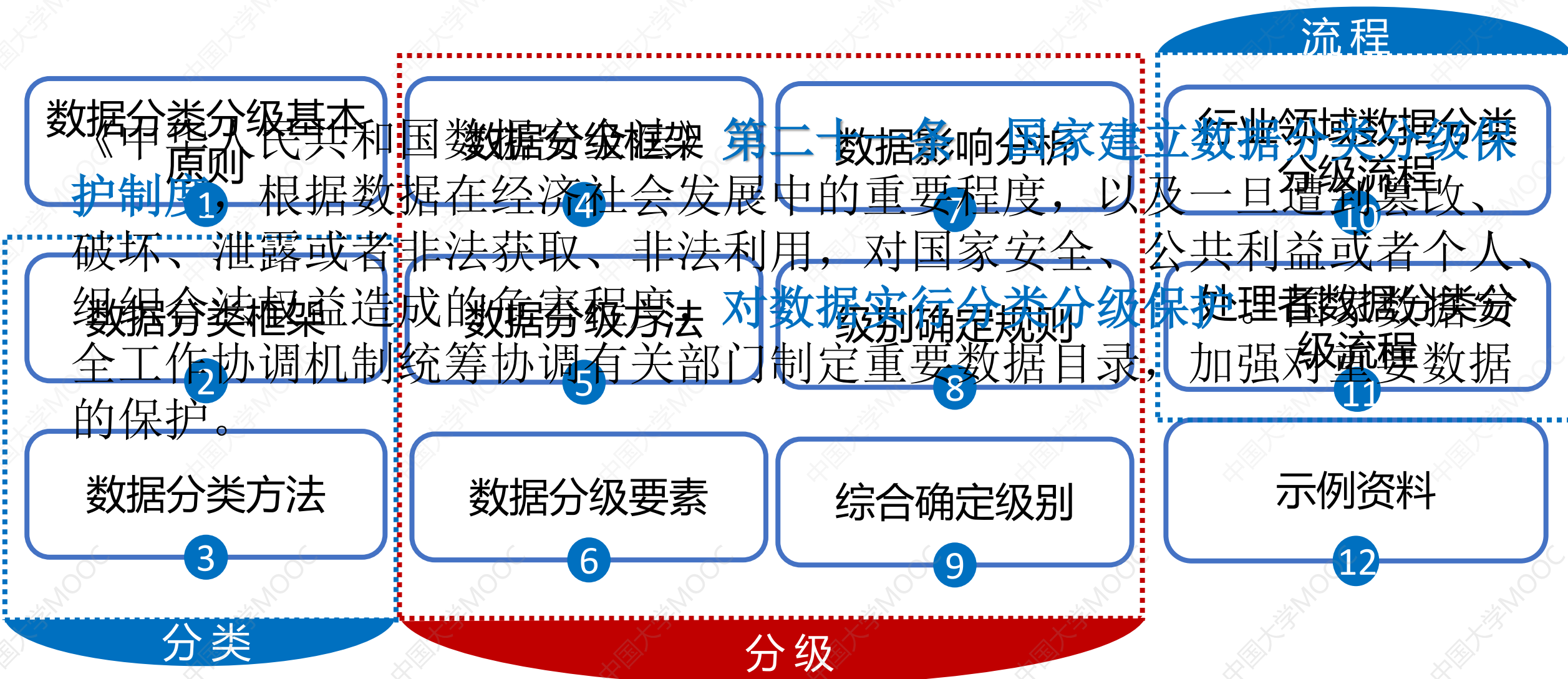
浙江省地方标准 DB33T 2351-2021 《数字化改革 公共数据分类分级指南》

数据级别	级别标识	判断标准
L4 级	敏感	有下列情形之一： 对全社会、多个行业、行业内多个组织造成严重影响； 对单个组织的正常运作造成极其严重影响； 对人身和财产安全、个人名誉造成严重损害。
L3 级	较敏感	有下列情形之一： 对全社会、多个行业、行业内多个组织造成中等程度的影响； 对单个组织的正常运作造成严重影响； 对个人名誉造成中等程度的损害。
L2 级	低敏感	有下列情形之一： 对全社会、多个行业、行业内多个组织造成轻微影响； 对单个组织的正常运作造成中等程度或轻微影响；对个人的合法权益造成轻微损害。
L1 级	不敏感	对社会秩序、公共利益、行业发展、信息主体均无影响。



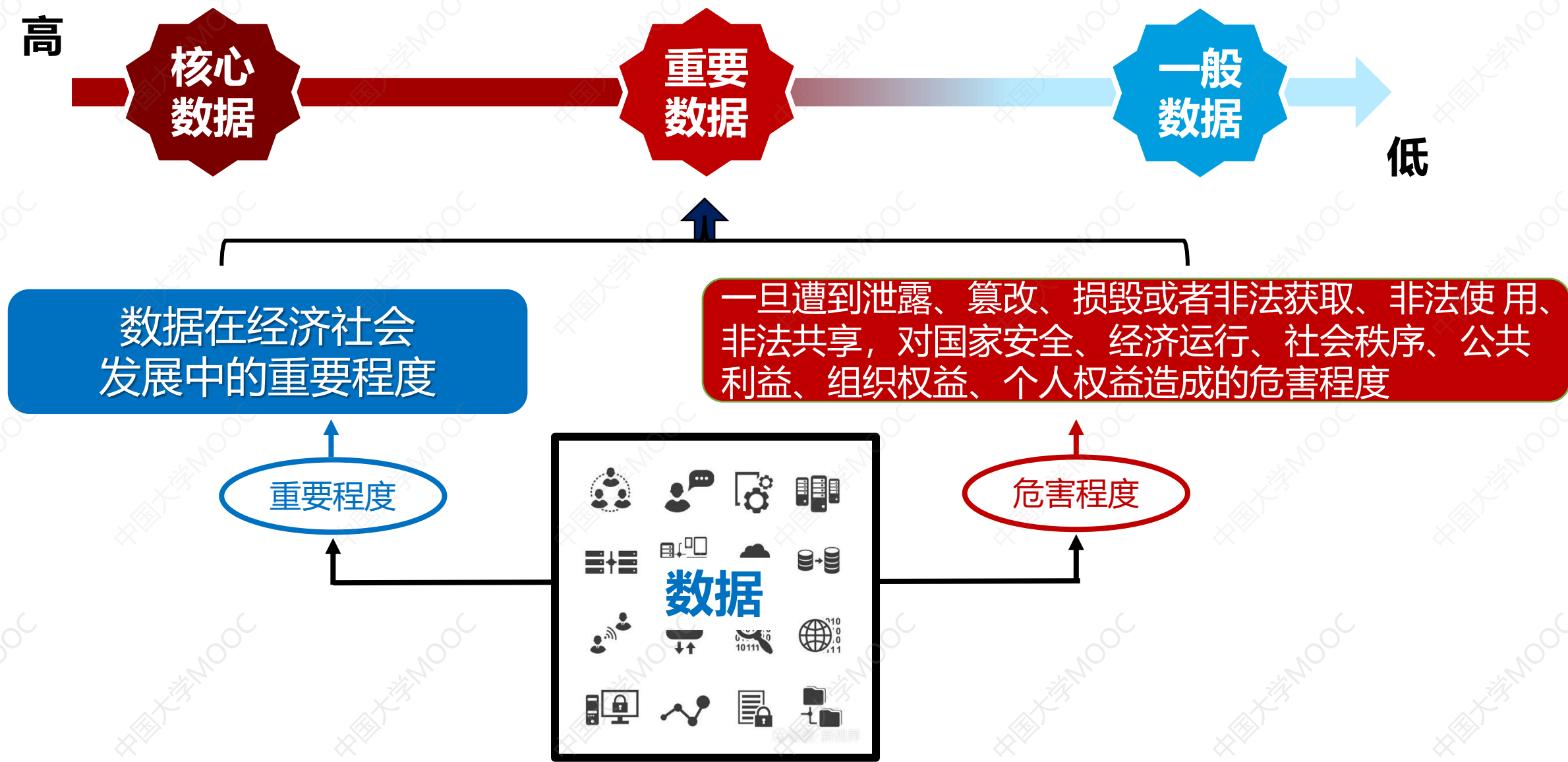
1.分类分级-标准

2024.3.15正式发布，将于2024.10.1开始施行的国家标准 GB/T 43697-2024 《数据安全技术 数据分类分级规则》





GB/T 43697-2024 《数据安全技术 数据分类分级规则》 分级框架





GB/T 43697-2024 《数据安全技术 数据分类分级规则》 分级方法

确定分级对象

确定待分级的数据，如**数据项**、**数据集**、**衍生数据**、**跨行业领域数据**等。

分级要素识别

结合自身数据特点，按照“**6.3 数据分级要素**”识别数据涉及的分级要素情况。

数据影响分析

结合数据分级要素识别情况，分析数据一旦遭到泄露、篡改、损毁或者非法获取、非法使用，非法共享，可能影响的对象和影响程度(见**6.4 数据影响分析**)。

综合确定级别

按照“**6.5 级别确定规则**”和“**6.6 综合确定级别**”内容综合确定数据级别。

定性：领域、群体、区域、重要性

定量：精度、规模、覆盖度

衍生数据：深度

国家安全、经济运行、社会秩序、公共利益、组织权益、个人权益



GB/T 43697-2024 《数据安全技术 数据分类分级规则》 级别确定规则

影响对象	影响程度		
	特别严重危害	严重危害	一般危害
国家安全	核心数据	核心数据	重要数据
经济运行	核心数据	重要数据	一般数据
社会秩序	核心数据	重要数据	一般数据
公共利益	核心数据	重要数据	一般数据
组织权益、个人权益	一般数据	一般数据	一般数据

注:如果影响大规模的个人或组织权益,影响对象可能不只包括个人权益或组织权益,也可能对国家安全、经济运行、社会秩序或公共利益造成影响。



GB/T 43697-2024 《数据安全技术 数据分类分级规则》 综合确定级别

1.按级别确定规则识别

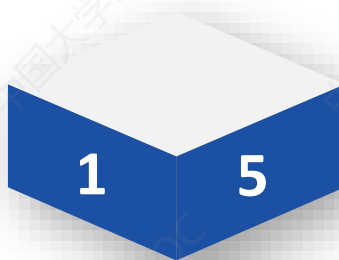
核心数据、重要数据和一般数据

2.重要数据识别

3.就高从严原则

多个要素、多个影响对象或影响程度

4.数据集级别确定



5.一般数据进行细化分级

6.衍生数据级别确定

就高从严、深度

7.跨行业领域数据级别确定

按照数据来源的行业领域

8.数据级别动态更新

规模变化，加工处理、事件影响、相关政策



GB/T 43697-2024 《数据安全技术 数据分类分级规则》 一般数据4级参考

数据级别	特点	传播范围
4级数据	数据一旦遭到泄露、篡改、损毁或者非法获取非法使用、非法共享，对个人权益、组织权益造成 特别严重危害 ，或对经济运行、社会秩序公共利益造成一般危害。	4级数据 按照批准的授权列表 严格管理，仅能在受控范围内经过严格审批、评估后才可共享或传播。
3级数据	数据一旦遭到泄露、篡改、损毁或者非法获取非法使用、非法共享，对个人权益、组织权益造成 严重危害 。	3级数据 仅可由授权的内部机构或人员访问 ，如果要数据共享到外部需要满足相关条件并获得相关方的授权。
2级数据	数据一旦遭到泄露、篡改、损毁或者非法获取非法使用、非法共享，对个人权益、组织权益造成 一般危害 。	2级数据通常在 组织内部、关联方共享和使用 ，相关方授权后可向组织外部共享
1级数据	数据一旦遭到泄露、篡改、损毁或者非法获取非法使用、非法共享 不会 对个人权益、组织权益等造成 危害 。	1级数据具有公共传播属性， 可对外公开发布、转发传播，但也需考虑公开的数据量及类别 ，避免由于类别较多或者数量过大被用于关联分析。



GB/T 43697-2024 《数据安全技术 数据分类分级规则》一般数据4级参 个人敏感信息（GB/T 35273）

个人身份信息	身份证、军官证、护照、驾驶证、工作证、社保卡、居住证等
网络身份标识信息	系统账号、邮箱地址及与前述有关的密码、 口令、口令保护答案 、用户个人数字证书等
个人健康生理	个人因 生病医治 等产生的相关 记录 ，如病症、住院志、医单、检验报告、手术及麻醉记录、护理记录、用药记录、药物食物过敏信息、生育信息、以往病史、诊治情况、家族病史、现病史、传染病史等，以及与个人身体健康状况产生的相关信息等
个人生物识别信息	个人基因 、指纹、声纹、掌纹、耳廓、虹膜、面部识别特征等
个人财产信息	银行账号 、鉴别信息(口令)、存款信息(包括资金数量、支付收款记录等)、房产信息、信贷记录、征信信息、 交易和消费记录 、流水记录等，以及虚拟货币、虚拟交易、游戏类兑换码等 虚拟财产信息
其他信息	个人电话号码 、性取向、婚史、宗教信仰、 未公开的违法犯罪记录 、 通信记录 和内容、行踪轨迹、 网页浏览记录 、 住宿信息 、 精准定位信息 等



模式匹配技术：正则表达式、关键词字典等

正则表达式 (Regular Expression) 描述了一种字符串匹配的模式，可以用来检查一个串是否含有某字符串。

- 身份证号码 正则表达式：**

`^d{15}|d{18}`

`(^d{15}$)|(^d{17}([0-9]|X|x)$)`

`(^[1-9]\d{5}(19|20)\d{2}(0[1-9]|1[0-2])(0[1-9]|1[12]\d|3[01])\d{3}[\dXx]$)|(^[1-9]\d{7}(0[1-9]|1[0-2])(0[1-9]|1[12]\d|3[01])\d{3}$)`



文本分析技术：自然语言处理、LLM、RAG等

对结构化或非结构化文本数据进行内容理解，并结合国家、行业和地方标准进行分类分级。

图像识别技术：字符识别、目标检测、图像分割等

对图片和视频数据进行内容理解，并结合国家、行业和地方标准进行分类分级。



遵循原则：最小化授权原则

超级管理员

业务管理员

业务处理员

普通老百姓

开发管理员

运维处理员

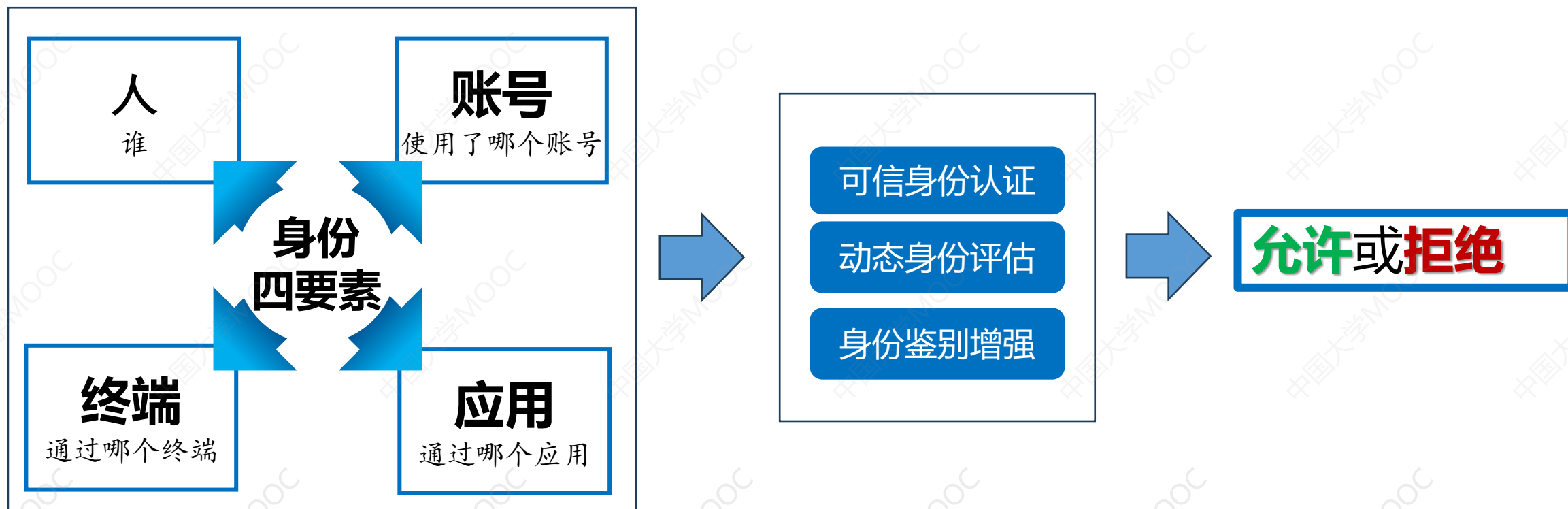
外协单位

根据 业务 最小化 授权访问角色;
根据 角色 最小化 授权数据功能;
根据 功能 最小化 授权访问时间;



遵循原则：以资产为核心，持续的身份认证

确保正确的人在正确的时间以正确的理由访问正确的资源





数据库防火墙

面向运维人员：

对数据库的访问进行细粒度控制，根据最小授权原则，根据用户身份、角色、IP、时间等因素分配权限，降低内部威胁风险。

面向老百姓：

使用语义发现、异常检测等技术，发现SQL注入企图，阻断恶意SQL语句，避免数据泄露。

面向所有访问者：

详细记录数据库访问日志，涵盖SQL语句、会话信息、返回结果，深入洞察用户行为模式，及时定位违规操作。



《密码法》明确规定了“建立和完善商用密码标准体系”

截至2024年7月，我国已颁布密码标准248项，其中密码国家标准为97项，密码行业标准为151项。

涵盖密码算法、密码协议、密码产品、密码应用和密码测评等多个方面

密码标准已成为密码从业人员开发密码产品以及在应用系统中正确使用密码的指导和依据。



加密算法：

对称加密算法：SM4，DES，AES

非对称加密算法：SM2，RSA，ECC

消息摘要算法：SM3，SHA256，SHA1，MD5

密钥协商算法：Diffie-Hellman，量子密码交换

数据加密单位：

字段加密

记录加密

全表加密

数据胶囊

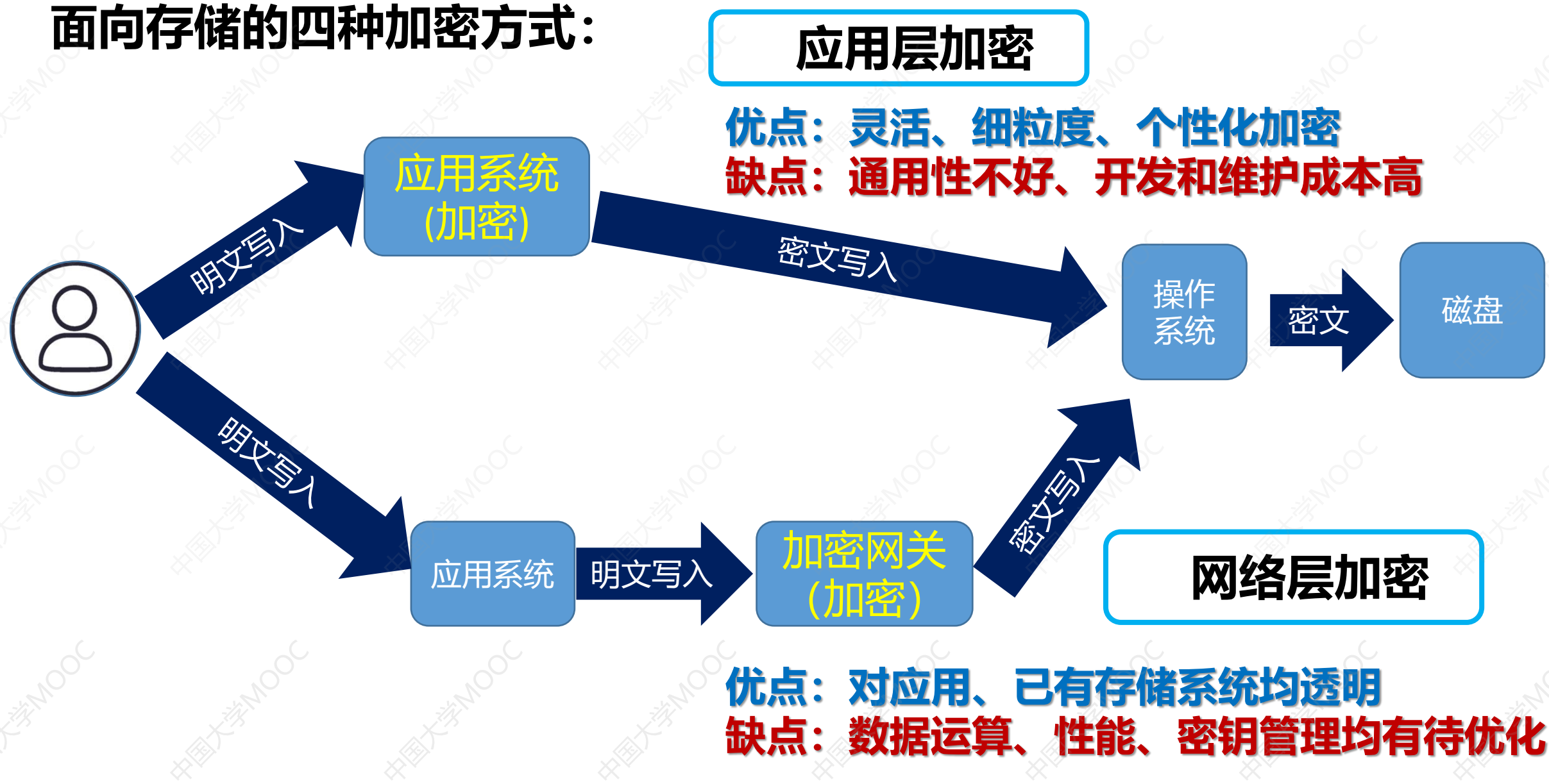


面向存储的四种加密方式：





面向存储的四种加密方式：

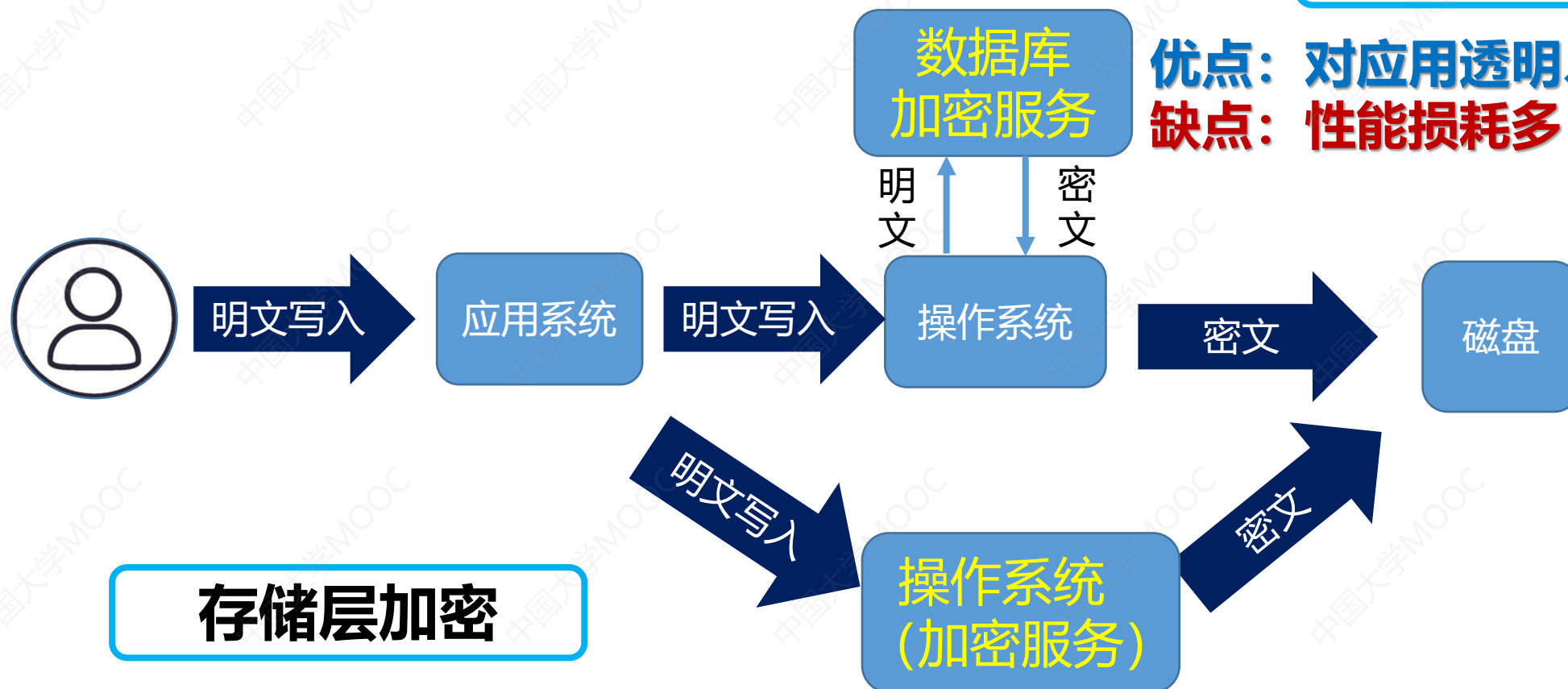




面向存储的四种加密方式：

数据库层加密

优点：对应用透明、支持数据运算
缺点：性能损耗多，依赖于数据库系统



存储层加密

优点：对应用透明

缺点：仅磁盘加密，不支持数据运算，数据仍以明文流转



密钥管理：负责密钥的产生、分发、存储、使用（停用、更新）、衍生、销毁等全流程的管理

- (1).制定密钥管理的策略和机制（根据面临的风险和实际预算）
- (2).密钥责任分离（单个密钥承担单项任务，加密、签名、哈希等算法之一）
- (3).密钥分级使用（主密钥、二级密钥、初级密钥）
- (4).全生命周期安全管理（从产生到分发...销毁全过程安全管理）
- (5).密钥定期更换（越频繁使用的密钥，更新频率应该更高）
- (6).密钥强度保证（足够长，足够随机）



脱敏方法:

举例子:

打*法: 关键字或部分字用*替换

吕**

K匿名化: 针对同一个检索词至少有K个

肺炎

肺炎

肺炎

肺炎

泛化法: 将具体的数字归到同一个范围

30-50岁

差分隐私: 传统差分隐私、本地差分隐私

P概率(杭电老师)

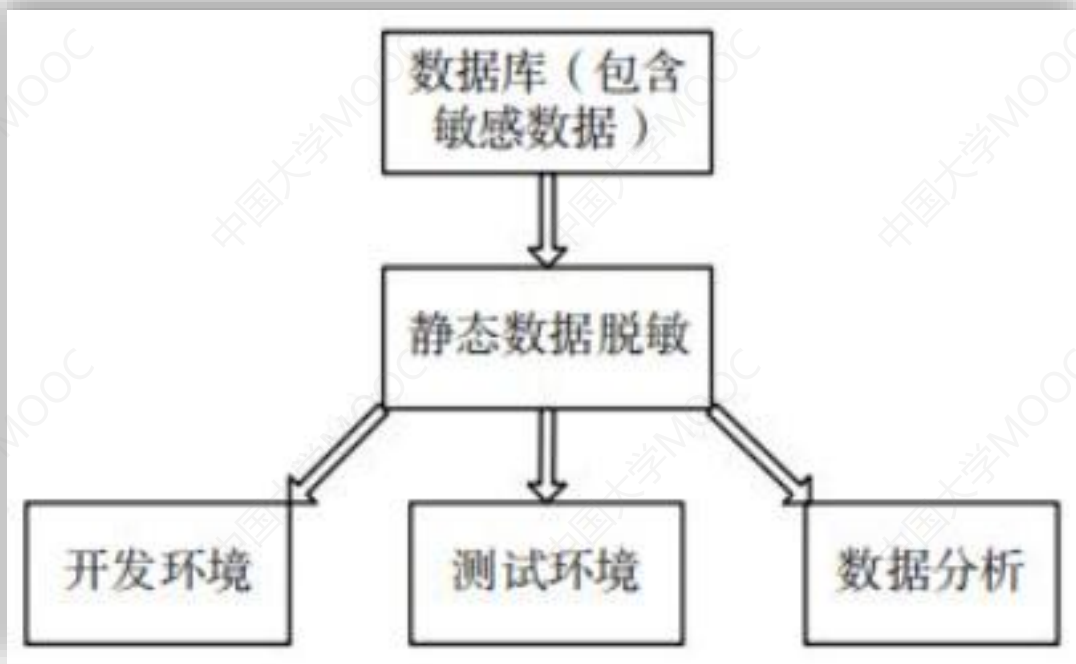
加密: 将敏感信息加密处理

不可逆

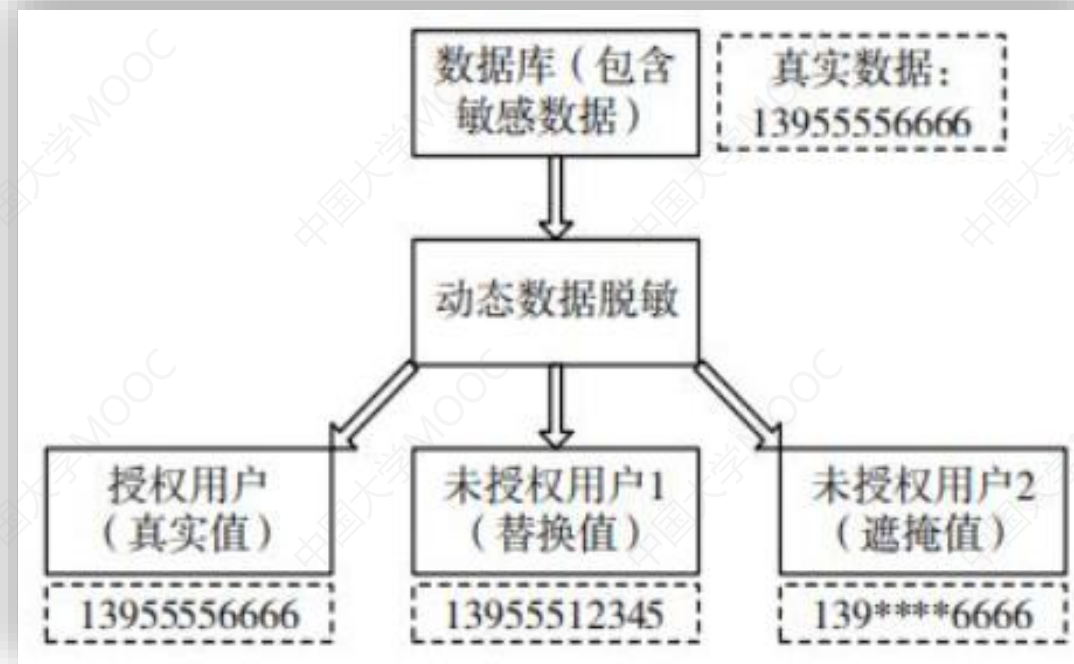


脱敏方式：

静态脱敏



动态脱敏





水印嵌入方法:

图像和音频水印嵌入算法: LSB, DWT, DCT

视频水印嵌入方法: 基于关键帧, 基于深度学习

文本水印嵌入方法: 基于语义, 基于格式

数据库表水印嵌入算法: 基于行嵌入, 基于表嵌入

可见水印

透明水印

静态水印

动态水印

视频或软件



无痕水印：

为水印内容构建HASH映射表，并将**HASH值转换为人眼和常规数据分析工具完全不可见的Unicode 编码标准中的零宽度字符**（Zero-Width Characters）**嵌入**文本内容中，例如：二进制的“0”被映射为“零宽空格”（\u200B），而二进制的“1”被映射为“零宽非连接符”（\u200C）。

伪行水印：

基于样本的统计特征，系统生成**一行或多行伪造数据**。伪造行在统计上与上下文数据“无法区分”，从而实现了高度伪装。并为水印内容与该伪行构建映射表。

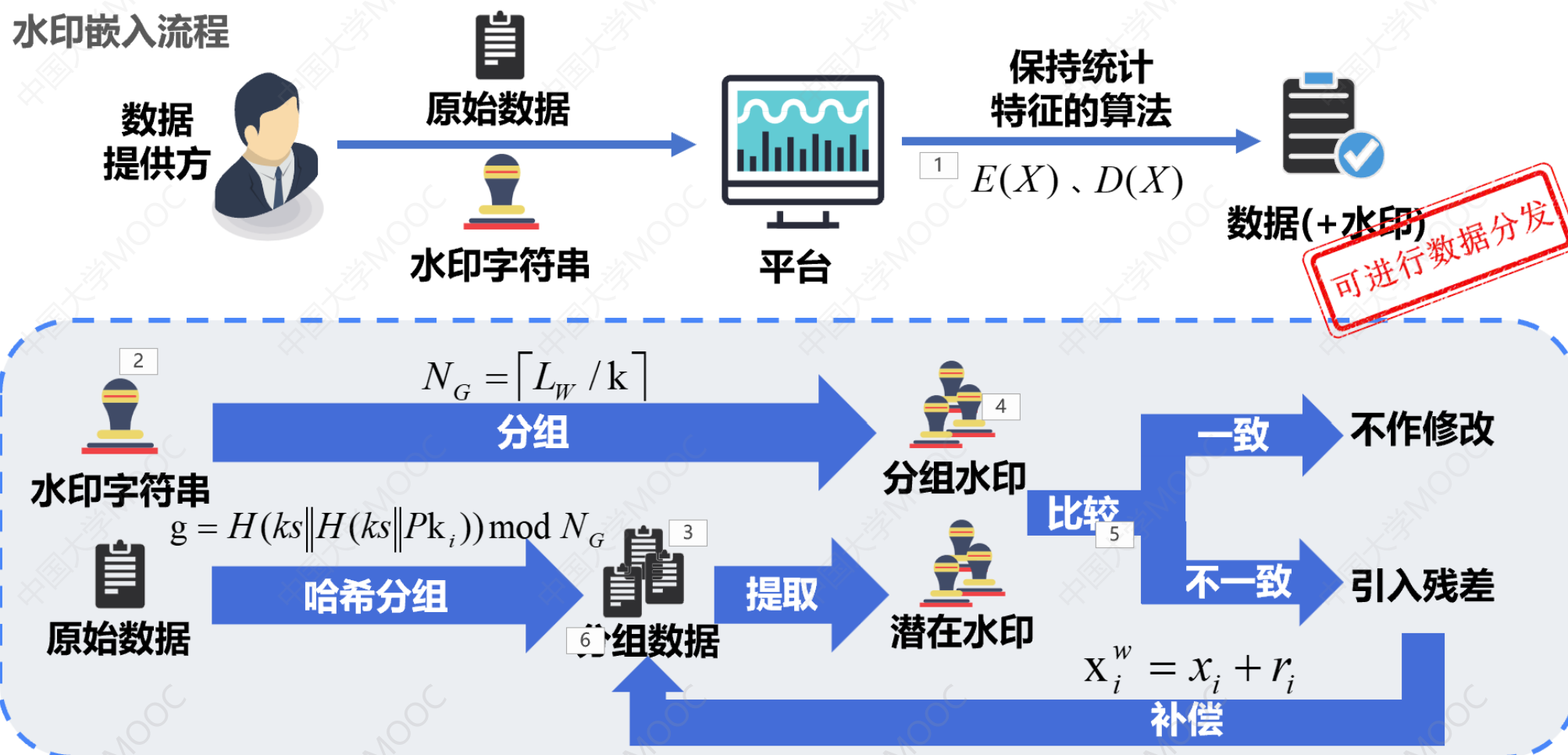
伪列水印：

通过生成一组与数据集行数相等、在特定范围内（如 1-5000）的唯一随机整数，形成**一系列或多列伪造数据**，并将伪列名+伪列随机抽样的“样本值”与嵌入水印内容进行映射。



保持统计特征的水印算法:

水印嵌入流程



来源: Ren Z, Fang H, Zhang J, et al. A robust database watermarking scheme that preserves statistical characteristics[J]. IEEE Transactions on Knowledge and Data Engineering, 2023, 36(6): 2329-2342.



保序加密水印算法

水印嵌入流程



来源: Hu D, Wang Q, Yan S, et al. Reversible database watermarking based on order-preserving encryption for data sharing[J]. ACM Transactions on Database Systems, 2023, 48(2): 1-25.



数据库水印的用法:

版权认证:

数据拥有者用密钥产生水印并将其嵌入载体数据库，然后公开发布含水印的数据库。

盗版追踪:

对发布给不同用户的数据库嵌入具有唯一性的不同版权标识（版权所有者信息+授权用户的信息），实现对版权协议背叛者的追踪。

访问控制:

在已有的基于角色的访问控制机制的基础上，采用数字水印技术将授权和配置策略隐式和动态地表达出来并嵌入数据库，从而提高数据库访问控制的安全性。

内容完整性验证:

通过检测出来的水印的破损程度判断载体数据来源的真实、内容的完整性等。

鲁棒性

脆弱性



6.API接口监测

[illegible]

API接口监测：

API接口分布,
API接口访问详情,
API接口台账,
API属性与状态
API接口涉敏状态
API接口违规使用 (二次封装)

.....

API接口脆弱性

API接口风险



面临挑战：如何有效监测接口的合法使用状态

- 横向越权使用、纵向越权使用等显式恶意调用API接口的攻击
- 接口数据最小化授权的困境，如接口返回的数据多于业务所需，长期的水滴攻击等隐式攻击手法
- 二次封装API接口





面临挑战：虚警率高，真实漏报率未知

- 现有数据安全态势感知的核心主要依赖于基于规则的网络数据流的分析，未能与身份、角色、上下文环境有机融合；且事件源、数据源均来自不同的产品和多家厂商，使得虚警率居高不下。
- 虽然态势感知平台有实验数据的漏报率，但真实业务场景中的攻击事件的漏报率未有可信方法进行验证。



- **数据销毁**是指通过物理粉碎、消磁和数据覆写等方式，实现数据的永久破坏，使数据无法通过任何手段恢复。
 - **物理粉碎**：使用特制的粉碎刀具，将介质粉碎成指定颗粒，破坏物理结构。
 - **消磁**：利用强磁场破坏磁介质上的数据存储特性，实现数据清除。
 - **数据覆写**：通过反复写随机数据或者加密覆写数据，将原有的存储数据彻底替换，达到不可逆销毁。

网络数据如何销毁？（远程，多副本，云存储）



杭州电子科技大学
HANGZHOU DIANZI UNIVERSITY

问题？！